

Vulnerability Management – CST8803

Final Project

Project Team

Mohamed Mahmoud - 040592809

Oderinlo Oluwatoni - 040975977

Abubakr Osman – 041135078

Version: 1.11

Problem Statement

The CSA271.com company's recent acquisition of the MXP2 system, designed to store highly sensitive data, raises concerns about potential vulnerabilities and security threats. The CEO is particularly worried about the possibility of DDoS attacks, considering the current political situation. The task is to conduct a comprehensive security assessment, identify vulnerabilities, and propose a solution to mitigate these risks. Also, the team must spare a Windows 10 machine for monitoring and detecting Various DDOS attempts (Sync flood, IP flood, ICMP flood, HTTP DDOS, TCP UDP flood) on Company subnet.

Work Processes

The follow the following processes to achieve the goal of the CSA271.com management:

1- Security assessment Environment Setup

Three virtual machines were configured for the assessment: MXP2 server, Kali Linux, and a Windows 10 machine for monitoring attacks.

2- Access to MXP2 Server Virtual Appliances

Gained access to MXP2 server virtual appliances to perform a thorough security assessment.

3- Assessment Phases

- Conducted a group of discoveries and assessment scans (using Tenable Nessus) on CSA271.com company's assets.
- Expanded the assessment scope to include the newly acquired critical system, MXP2, and developed a mechanism for monitoring potential attacks on company assets by acquiring Win 10 server.
- Three Tenable Nessus reports are attached with this report.
- The 3 VM's report's (Kali, MXP2 and Windows 10) were gotten from Nessus on the Jump box on Cyber Range (Nessus reports attached).

Critical vulnerabilities

A thoroughly scan done on MXP2 as follows:

Start time: Mon Dec 4 11:54:10 2023

End time: Mon Dec 4 12:12:38 2023

IP: 10.10.4.2

OS: Linux Kernel 2.6.24-16-server on Ubuntu 8.04

23 critical vulnerabilities found on MXP2 bellow are 11 of them with CVSS score 8+ (Actual Nessus report attached)

1- 182252 - Apache Log4j SEoL (<= 1.x)

CVSS Score: 10

Description: According to its version, Apache Log4j is less than or equal to 1.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Mitigation: Upgrade to a version of Apache Log4 that is currently supported.

2- 2. 77823 - Bash Remote Code Execution (Shellshock)

CVSS Score: 9.8

Description: The remote host is running a version of Bash that is vulnerable to command injection via environment variable manipulation. Depending on the configuration of the system, an attacker could remotely execute arbitrary code.

Mitigation: Update Bash.

3- 32314 - Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

CVSS Score: 10

Description: The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

Mitigation: Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

4- 32432 - Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : gnutls12, gnutls13 vulnerabilities (USN-613-1)

CVSS Score: 10

Description: Multiple flaws were discovered in the connection handling of GnuTLS. A remote attacker could exploit this to crash applications linked against GnuTLS, or possibly execute arbitrary code with permissions of the application's user.

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected packages.

5- 33531 - Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : linux, linux-source-2.6.15/20/22 vulnerabilities (USN-625-1)

CVSS Score: 10

Description: Dirk Nehring discovered that the IPsec protocol stack did not correctly handle fragmented ESP packets. A remote attacker could exploit this to crash the system, leading to a denial of service.

(CVE-2007-6282) Johannes Bauer discovered that the 64bit kernel did not correctly handle hrtimer updates. A local attacker could request a large expiration value and cause the system to hang, leading to a denial of service.

(CVE-2007-6712)

Tavis Ormandy discovered that the ia32 emulation under 64bit kernels did not fully clear uninitialized data. A local attacker could read private kernel memory, leading to a loss of privacy.

(CVE-2008-0598)

Jan Kratochvil discovered that PTRACE did not correctly handle certain calls when running under 64bit kernels. A local attacker could exploit this to crash the system, leading to a denial of service.

(CVE-2008-1615)

Wei Wang discovered that the ASN.1 decoding routines in CIFS and SNMP NAT did not correctly handle certain length values. Remote attackers could exploit this to execute arbitrary code or crash the system.

(CVE-2008-1673)

Paul Marks discovered that the SIT interfaces did not correctly manage allocated memory. A remote attacker could exploit this to fill all available memory, leading to a denial of service.

(CVE-2008-2136)

David Miller and Jan Lieskovsky discovered that the Sparc kernel did not correctly range-check memory regions allocated with mmap. A local attacker could exploit this to crash the system, leading to a denial of service.

(CVE-2008-2137)

The sys_utimensat system call did not correctly check file permissions in certain situations. A local attacker could exploit this to modify the file times of arbitrary files which could lead to a denial of service.

(CVE-2008-2148)

Brandon Edwards discovered that the DCCP system in the kernel did not correctly check feature lengths. A remote attacker could exploit this to execute arbitrary code.

(CVE-2008-2358)

A race condition was discovered between ptrace and utrace in the kernel. A local attacker could exploit this to crash the system, leading to a denial of service.

(CVE-2008-2365)

The copy_to_user routine in the kernel did not correctly clear memory destination addresses when running on 64bit kernels. A local attacker could exploit this to gain access to sensitive kernel memory, leading to a loss of privacy.

(CVE-2008-2729)

The PPP over L2TP routines in the kernel did not correctly handle certain messages. A remote attacker could send a specially crafted packet that could crash the system or execute arbitrary code.

(CVE-2008-2750)

Gabriel Campana discovered that SCTP routines did not correctly check for large addresses. A local user could exploit this to allocate all available memory, leading to a denial of service.

(CVE-2008-2826).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected packages.

6- 49805 - Ubuntu 6.06 LTS / 8.04 LTS / 9.04 / 9.10 / 10.04 LTS / 10.10 : openssl vulnerabilities(USN-1003-1)

CVSS Score: 10

Description: It was discovered that OpenSSL incorrectly handled return codes from the bn_wexpand function calls. A remote attacker could trigger this flaw in services that used SSL to cause a denial of service or possibly execute arbitrary code with application privileges. This issue only affected Ubuntu 6.06 LTS, 8.04 LTS, 9.04 and 9.10.

(CVE-2009-3245)

It was discovered that OpenSSL incorrectly handled certain private keys with an invalid prime. A remote attacker could trigger this flaw in services that used SSL to cause a denial of service or possibly execute arbitrary code with application privileges. The default compiler options for affected releases should reduce the vulnerability to a denial of service.

(CVE-2010-2939).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected packages.

7- 37337 - Ubuntu 7.10 / 8.04 LTS / 8.10 : linux, linux-source-2.6.22 vulnerabilities (USN-751-1)

CVSS Score: 10

Description: NFS did not correctly handle races between fcntl and interrupts. A local attacker on an NFS mount could consume unlimited kernel memory, leading to a denial of service. Ubuntu 8.10 was not affected.

(CVE-2008-4307)

Sparc syscalls did not correctly check mmap regions. A local attacker could cause a system panic, leading to a denial of service. Ubuntu 8.10 was not affected.

(CVE-2008-6107)

In certain situations, cloned processes were able to send signals to parent processes, crossing privilege boundaries. A local attacker could send arbitrary signals to parent processes, leading to a denial of service.

(CVE-2009-0028)

The kernel keyring did not free memory correctly. A local attacker could consume unlimited kernel memory, leading to a denial of service.

(CVE-2009-0031)

The SCTP stack did not correctly validate FORWARD-TSN packets. A remote attacker could send specially crafted SCTP traffic causing a system crash, leading to a denial of service.

(CVE-2009-0065)

The eCryptfs filesystem did not correctly handle certain VFS return codes. A local attacker with write-access to an eCryptfs filesystem could cause a system crash, leading to a denial of service.

(CVE-2009-0269)

The Dell platform device did not correctly validate user parameters. A local attacker could perform specially crafted reads to crash the system, leading to a denial of service.

(CVE-2009-0322)

The page fault handler could consume stack memory. A local attacker could exploit this to crash the system or gain root privileges with a Kprobe registered. Only Ubuntu 8.10 was affected.

(CVE-2009-0605)

Network interfaces statistics for the SysKonnnect FDDI driver did not check capabilities. A local user could reset statistics, potentially interfering with packet accounting systems.

(CVE-2009-0675)

The getsockopt function did not correctly clear certain parameters. A local attacker could read leaked kernel memory, leading to a loss of privacy.

(CVE-2009-0676)

The ext4 filesystem did not correctly clear group descriptors when resizing. A local attacker could exploit this to crash the system, leading to a denial of service.

(CVE-2009-0745)

The ext4 filesystem did not correctly validate certain fields. A local attacker could mount a malicious ext4 filesystem, causing a system crash, leading to a denial of service. (CVE-2009-0746, CVE-2009-0747, CVE-2009-0748)

The syscall interface did not correctly validate parameters when crossing the 64-bit/32-bit boundary. A local attacker could bypass certain syscall restricts via crafted syscalls.

(CVE-2009-0834, CVE-2009-0835)

The shared memory subsystem did not correctly handle certain shmctl calls when CONFIG_SHMEM was disabled. Ubuntu kernels were not vulnerable, since CONFIG_SHMEM is enabled by default.

(CVE-2009-0859)

The virtual consoles did not correctly handle certain UTF-8 sequences. A local attacker on the physical console could exploit this to cause a system crash, leading to a denial of service.

(CVE-2009-1046).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected packages.

8- 58743 - Ubuntu 8.04 LTS / 10.04 LTS / 11.04 / 11.10 : samba vulnerability (USN-1423-1)

CVSS Score: 10

Description: Brian Gorenc discovered that Samba incorrectly calculated array bounds when handling remote procedure calls (RPC) over the network. A remote, unauthenticated attacker could exploit this to execute arbitrary code as the root user.

(CVE-2012-1182).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected samba package.

9- 40529 - Ubuntu 8.04 LTS / 8.10 / 9.04 : apr vulnerability (USN-813-1)

CVSS Score: 10

Description: Matt Lewis discovered that apr did not properly sanitize its input when allocating memory. If an application using apr processed crafted input, a remote attacker could cause a denial of service or potentially execute arbitrary code as the user invoking the application.

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

Mitigation: Update the affected libapr1, libapr1-dbg and / or libapr1-dev packages.

10- 33850 - Unix Operating System Unsupported Version Detection

CVSS Score: 10

Description: According to its self-reported version number, the Unix operating system running on the remote host is no longer supported.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities.

Mitigation: Upgrade to a version of the Unix operating system that is currently supported.

11- 32320 - Weak Debian OpenSSH Keys in ~/.ssh/authorized_keys

CVSS Score: 9.8

Description: The remote host has one or more ~/.ssh/authorized_keys files containing weak SSH public keys generated on a Debian or Ubuntu system.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

This problem does not only affect Debian since any user uploading a weak SSH key into the ~/.ssh/authorized_keys file will compromise the security of the remote system.

An attacker could try a brute-force attack against the remote host and logon using these weak keys.

Mitigation: Remove all the offending entries from ~/.ssh/authorized_keys.

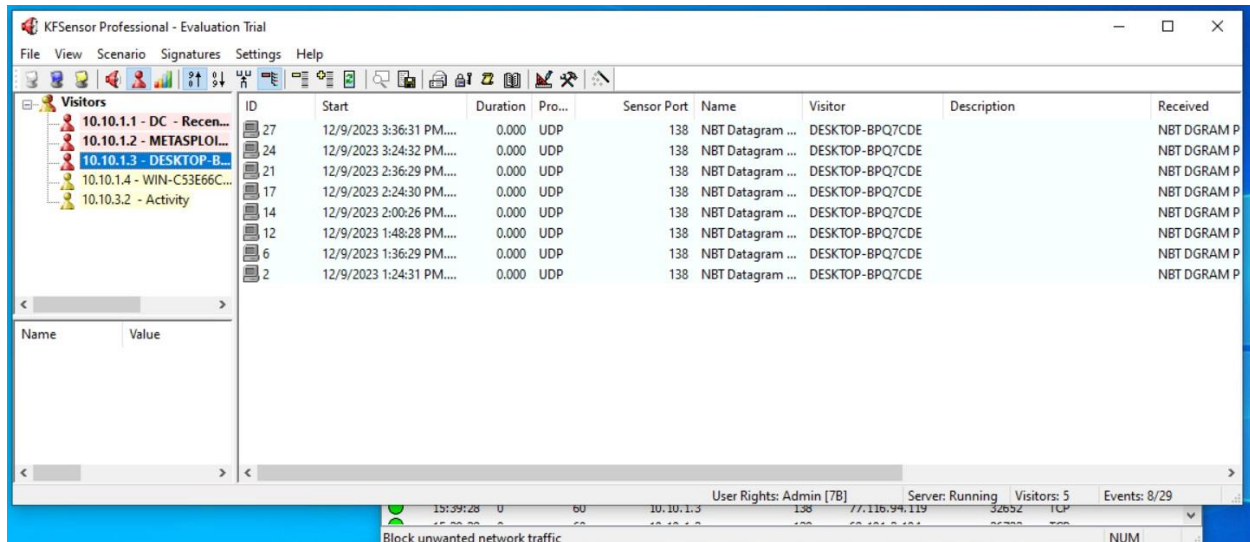
4- DDoS Monitoring Appliance

- A dedicated Windows 10 Server was allocated for monitoring, detecting and blocking various DDoS attempts on the Company's subnet.
- Implemented mechanisms to monitor and detect Sync flood, IP flood, ICMP flood, HTTP DDoS, TCP UDP flood by installing honeyPot KFSensor while installing Anti DDoS Guardian 6.1 as the blocking tool.

To generate flood attack we run the following command on Kali server with IP: 10.10.1.3.

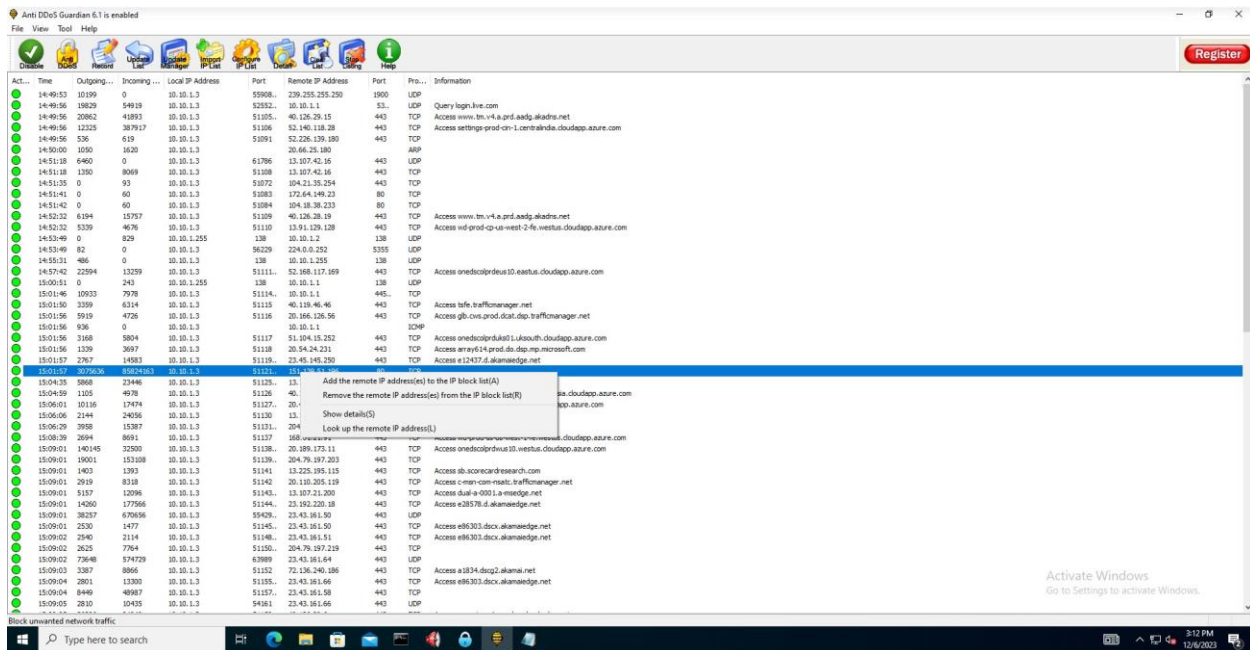
```
(root@kali)-[~]
# sudo hping3 -S -p 80 10.10.1.3 --flood --rand-source
HPING 10.10.1.3 (eth0 10.10.1.3): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

For detecting DDoS attacks, we installed KFSensor Professional on Windows 10 server.



On Windows 10 Server we installed Anti DDoS Guardian 61

Screen Shot before enable Anti DDoS guardian to block DDoS attack



In the figure bellow all traffic from flood attacker with IP: 10.10.1.3 are blocked by Anti DDoS Guardian

Anti DDoS Guardian 6.1 is enabled

File View Tool Help

Disable Anti DDoS Record Update List Update Manager Import IP List Configure IP List Details Clear List Stop Listing Help

Act...	Time	Outgoing...	Incoming ...	Local IP Address	Port	Remote IP Address	Port	Pro...	Information
●	12:52:11	34484	12867	10.10.1.3	51397..	10.10.1.1	53	UDP	Query
●	13:04:17	2635	0	10.10.1.3		10.10.1.1		ICMP	
●	13:04:21	420	660	10.10.1.3		203.232.51.2		ARP	
●	13:06:43	0	60(Blocked)	10.10.1.3	80	18.197.38.122	55807	TCP	
●	13:06:43	0	60(Blocked)	10.10.1.3	80	142.210.94.54	55808	TCP	
●	13:06:43	0	60(Blocked)	10.10.1.3	80	178.192.22.90	55810	TCP	
●	13:06:53	0	60(Blocked)	10.10.1.3	80	185.6.23.61	8264	TCP	
●	13:06:53	0	60(Blocked)	10.10.1.3	80	11.181.73.255	8265	TCP	
●	13:06:53	0	60(Blocked)	10.10.1.3	80	89.145.143.192	8266	TCP	
●	13:06:53	0	60(Blocked)	10.10.1.3	80	45.223.51.157	8267	TCP	
●	13:06:53	0	60(Blocked)	10.10.1.3	80	152.123.8.64	8268	TCP	
●	13:06:54	0	60(Blocked)	10.10.1.3	80	24.214.95.91	53597	TCP	
●	13:07:03	0	60(Blocked)	10.10.1.3	80	136.191.41.33	61604	TCP	
●	13:07:03	0	60(Blocked)	10.10.1.3	80	143.174.62.215	61605	TCP	
●	13:07:13	0	60(Blocked)	10.10.1.3	80	2.34.248.142	10544	TCP	
●	13:07:13	0	60(Blocked)	10.10.1.3	80	150.107.52.78	39185	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	64.2.106.88	47110	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	114.170.94.214	47111	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	147.61.139.118	47112	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	22.135.94.73	4316	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	36.25.97.54	4317	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	203.216.114.88	4318	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	61.70.143.61	4320	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	11.103.38.167	31444	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	185.227.185.92	31445	TCP	
●	13:07:24	0	60(Blocked)	10.10.1.3	80	240.33.156.192	56682	TCP	

Block unwanted network traffic

5- Recommendations

- Regularly update and patch the MXP2 system to address any newly discovered vulnerabilities.
- Implement strong access controls and authentication mechanisms to restrict unauthorized access to sensitive data.
- Conduct regular security audits and assessments to proactively identify and address potential security risks (this can be done by hiring consultants to assess and audit the security polices, update batches and security recovery plans to conduct this audit quarterly).

6- Conclusion:

The security assessment aims to ensure the integrity and confidentiality of CSA271.com's critical data. By identifying and mitigating potential vulnerabilities, implementing Anti DDoS system we strive to enhance the overall security posture of the organization.